PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Nettoyage de la politique de filtrage réseau

03-410 ANSSI - Nettoyage d'une politique de filtrage réseau d'un pare-feu — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La logique de first-match impose que la décision de la première règle correspondant à un flux soit appliquée sans évaluer la suite.
2. L'affinage est un processus itératif consistant à enrichir une règle amont avec les données des journaux d'une règle redondante jusqu'à ce que cette dernière ne produise plus d'événements.
3. Le nettoyage doit être mené de concert lorsque plusieurs pare-feux partagent des règles identiques afin de préserver la cohérence.

Nettoyage de la politique de filtrage

Notion	À retenir
Objectifs et causes	Viser la **cohérence**, la **compréhension** et la **restriction** aux flux légitimes. Causes : **complexité**, **absence de convention**, **renouvellement des équipes**, **manque de maîtrise de la cartographie**.
Prérequis politique et journaux	Logique **first-match**, **identifiant unique** par règle, **règles métier avant l'interdiction finale**. Journaux : inclure l'**identifiant** ; horloge **synchronisée** sur un **serveur de temps**.

Anomalies structurelles

Notion	À retenir
Objets doublons	Noms différents pour des caractéristiques identiques : compliquent la **mise à jour** et la **production d'indicateurs d'usage**.
Règles redondantes	Identiques à une **règle amont** (suppression possible) ou **contenue** par une règle amont (simplification possible).

Analyse des journaux

Notion	À retenir
Analyse pertinente	Journalisation **activée** sur toutes les règles. Période **représentative** de l'activité normale (ni trop courte pour les flux occasionnels, ni trop longue pour l'exploitabilité).
Règles/objets inutilisés	Règle sans événement sur la période : **inutilisée** (redondance, projet retiré ou usage occasionnel). Objet jamais observé dans les journaux de la règle : **retirable** sans modifier le comportement.

Méthodologie de nettoyage

Notion	À retenir
Préparation et conformité	Définir **modèle d'organisation**, **convention de nommage** et **marquage**. Vérifier **sauvegarde/restauration**. Méthode à **rejouer** (ex: **2 fois par an**) sur tous les pare-feux d'interconnexion. Traiter règles désactivées, objets inutilisés, doublons, puis appliquer la **convention de nommage** aux objets restants.
Suppression règles inutilisées	Contacter les **équipes métier**. Désactiver par **petits lots** avec **sauvegarde** après chaque lot. Conserver après désactivation pour **retour arrière** avant suppression définitive.
Redondance et simplification	Sauvegarder **avant/après**. Catégoriser les redondances. Simplifier en retirant **objets inutilisés** par lots, supprimer les **objets orphelins** à chaque itération avec **sauvegarde** systématique.

Processus d'affinage des règles (4e étape)

Notion	À retenir
Le principe itératif	Extraire adresses/ports des journaux d'une **règle redondante** pour enrichir une **règle en amont**. Cycle fini quand la règle redondante ne produit **plus aucun événement**.
Les précautions du processus	Analyse critique de la **légitimité** par des experts, réutilisation des **objets existants**, fixation d'un **niveau de précision maximal réaliste** et limitation des processus **en parallèle**.

Étapes de l'affinage et traçabilité

1. **Extraction** : identifier les adresses et ports réellement utilisés via les journaux d'une règle trop large.
2. **Enrichissement** : placer les éléments extraits dans une règle située en amont.
3. **Validation** : répéter le cycle jusqu'à l'absence totale d'événements sur la règle redondante.
4. **Suppression** : désactiver puis supprimer la règle devenue inutile.
5. **Traçabilité** : consigner chaque modification avec une **date** et une **référence** dans le champ **commentaire**.

Pièges et confusions

⚠ Croire que la méthode proposée est la seule possible ou forcément adaptée à tout contexte.
⚠ Oublier que le nettoyage peut avoir un fort impact sur les flux métiers en cas de suppression malencontreuse.
⚠ Négliger de communiquer avec les équipes métier et de valider les procédures de sauvegarde et de restauration au préalable.
⚠ Ne pas tenir compte de la cohérence entre les politiques lors du nettoyage de plusieurs pare-feux partageant des règles identiques.

Sigles et définitions

Logique de first-match	Parcours séquentiel où la décision de la première règle correspondant à un flux est appliquée sans évaluer la suite.
Objet doublon	Objet portant un nom différent mais dont les caractéristiques sont rigoureusement identiques à un autre.
Objet inutilisé (orphelin)	Objet défini dans la base mais qui n'est utilisé dans aucune règle de filtrage.
Règle redondante	Règle qui autorise un trafic déjà permis par une autre règle placée en amont.
Processus d'affinage	Démarche itérative consistant à enrichir une règle amont à partir des adresses et ports observés dans les journaux d'une règle redondante.
SPD (base d'objets)	Regroupe les objets réseau, service et groupe utilisés pour construire les règles.

Auto-test

1. Quelle est la conséquence d'un objet doublon ?
2. Quand un objet est-il considéré comme retirable sans modifier le comportement ?
3. À quelle fréquence faut-il appliquer la méthodologie de nettoyage ?
4. Que doit-on faire avec une règle inutilisée avant sa suppression définitive ?
5. Comment doit être consignée chaque modification pour la traçabilité ?

Réponses : **1.** Il compromet la mise à jour et la production d'indicateurs d'usage. · **2.** Lorsqu'il n'est jamais observé dans les journaux de la règle. · **3.** 2 fois par an. · **4.** La désactiver pour permettre un retour arrière. · **5.** Avec une date et une référence dans le champ commentaire.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.